

THREAT INTELLIGENCE ANALYSIS REPORT

Oski Lab

Malicious PPT Attachment — Stealc-Family Infostealer Campaign

Platform	CyberDefenders — Blue Team CTF Challenges
Lab Category	Threat Intelligence
Lab Name	Oski
Analyst	Kn
Report Date	June 16, 2026
Tools Used	VirusTotal, ANY.RUN Sandbox, MITRE ATT&CK Navigator, Threat.rip

1. Executive Summary

This report documents the analysis of the “Oski” Blue Team CTF challenge hosted on CyberDefenders, a threat-intelligence lab in which a malicious PowerPoint (.ppt) attachment delivered an information-stealing payload. The investigation was carried out using open-source and commercial threat-intelligence tooling — primarily VirusTotal and the ANY.RUN interactive sandbox — rather than direct dynamic detonation, which mirrors how a SOC analyst or threat-intel researcher would triage a similar alert using existing community sandbox reports and reputation data.

The investigation determined that the payload embedded in the PPT belongs to the Stealc infostealer family (a descendant of the Vidar/Oski lineage that the lab is named after), communicates with a command-and-control (C2) server at 171.22.28.221, loads sqlite3.dll as its first post-infection action to query browser credential databases, decrypts its configuration strings using a hardcoded RC4 key, executes MITRE ATT&CK technique T1555 (Credentials from Password Stores), and performs self-deletion five seconds after exfiltrating stolen data — deleting both its own executable and any DLLs dropped into C:\ProgramData\ to frustrate forensic recovery.

Each of the seven analysis objectives below is presented with the underlying tool, the specific feature or tab used, the rationale for that step, and the resulting finding, so the report functions both as a record of the investigation and as a repeatable methodology for similar Stealc/Oski-family triage in the future.

2. Scenario & Background

An accountant at the target company received an email titled “Urgent New Order” late in the afternoon from what appeared to be a client. The attached file was presented as an invoice, but on opening it the accountant found the order details inside did not match anything genuine. Shortly afterward, the organization’s SIEM raised an alert for a potentially malicious file download that originated from the same workstation. Initial triage pointed to the PPT attachment as the source of the download, and the analyst (in this case, the lab participant) was tasked with examining the file in depth to characterize the threat.

This pattern — a weaponized Office document used as an initial-access lure that silently retrieves or unpacks a second-stage stealer — is one of the most common phishing techniques observed in real incident response work, which is what makes this lab a useful proxy for production SOC alerts.

3. Tools & Methodology

The investigation followed a threat-intelligence pivoting methodology: rather than detonating the sample directly, the analyst used the file hash provided by the lab to pull existing reputation and sandbox data from public platforms, then pivoted between those platforms to fill in gaps that any single source did not cover.

3.1 VirusTotal

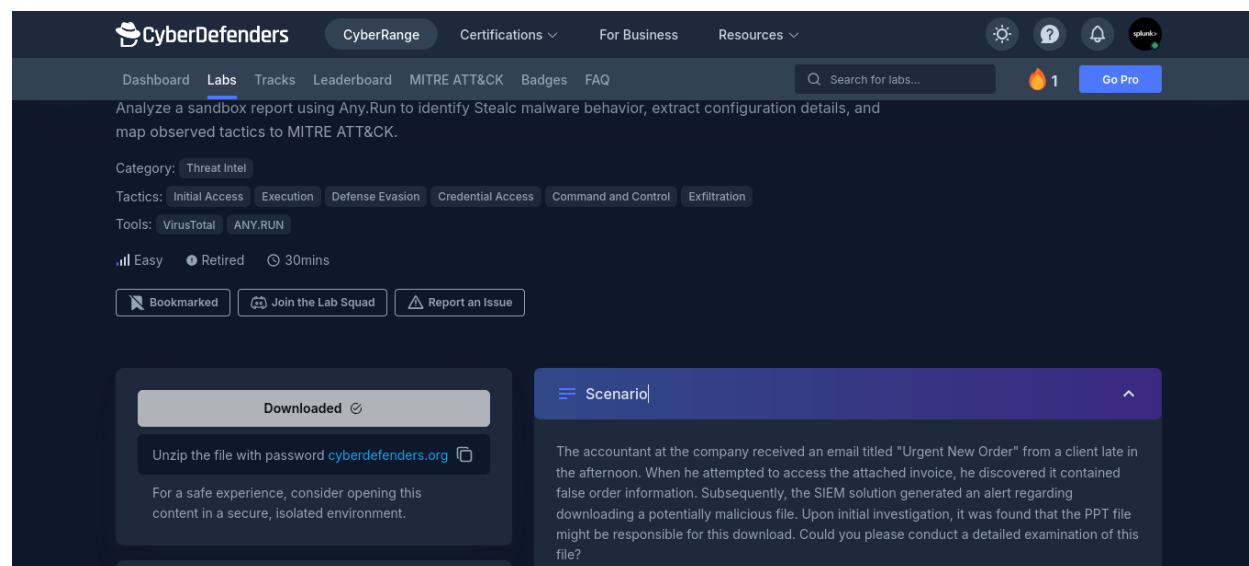
VirusTotal was used to confirm the file's reputation, view crowdsourced antivirus and IDS rule detections that named the malware family, and inspect the Details tab for compile/PE timestamp metadata.

3.2 ANY.RUN Interactive Sandbox

An existing public ANY.RUN sandbox run for the same file hash was used to observe actual runtime behavior: network requests, the process tree, the malware configuration extractor ("MalConf"), and the built-in MITRE ATT&CK mapping panel. ANY.RUN is particularly useful here because it captures behavior that static analysis alone cannot reveal — the specific libraries loaded, the literal C2 traffic, and the exact shell commands issued by child processes.

3.3 MITRE ATT&CK Framework

Findings from the sandbox were cross-referenced against MITRE ATT&CK technique IDs so that the malware's behavior could be expressed in a standardized, SOC-friendly vocabulary suitable for detection engineering and reporting.



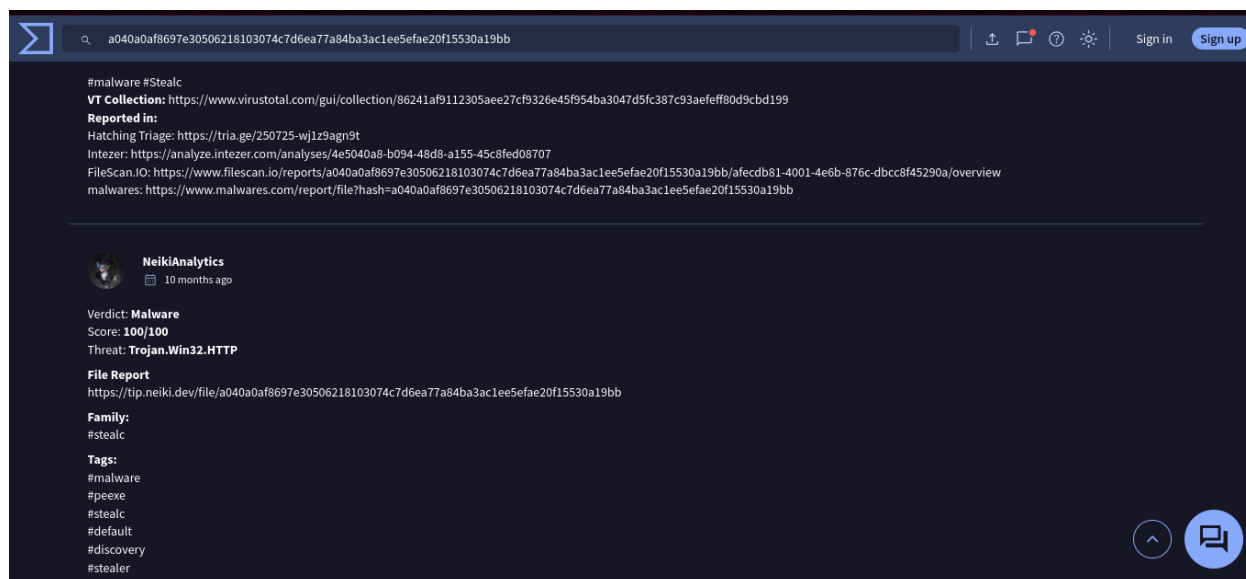
4. Investigation Findings

4.1 Objective 1 — Malware Family Identification

Goal: identify which malware family the executable embedded in the PPT belongs to, since family attribution determines which known TTPs, IOC patterns, and detection signatures are relevant.

Process:

1. Take the MD5/SHA-256 hash of the malicious file provided in the lab artifacts and submit it to VirusTotal's search bar.
2. Open the “Detection” tab and review the crowdsourced YARA/IDS rule matches, which are community-maintained signatures that label samples by family based on code and behavioral similarity.
3. Cross-check the family name against the Relations or Community tab for corroborating tags.



Finding

Stealc malware family

Stealc is itself a direct descendant of the Vidar and Oski stealer codebases (which is why the lab carries the Oski name), and it specializes in harvesting saved browser credentials, cookies, autofill data, and cryptocurrency wallet files. Recognizing this lineage matters operationally: defenses and YARA rules written for Oski/Vidar often catch Stealc variants too, and vice-versa.

4.2 Objective 2 — Malware Creation Time

Goal: determine when the malicious binary was compiled, to understand how long it had existed before this campaign and how it fits into a broader timeline of detections.

Process:

1. On the same VirusTotal report, open the “Details” tab.
2. Locate the “History” section, which lists the PE compile timestamp embedded in the file's header alongside the first-submission and last-analysis dates.

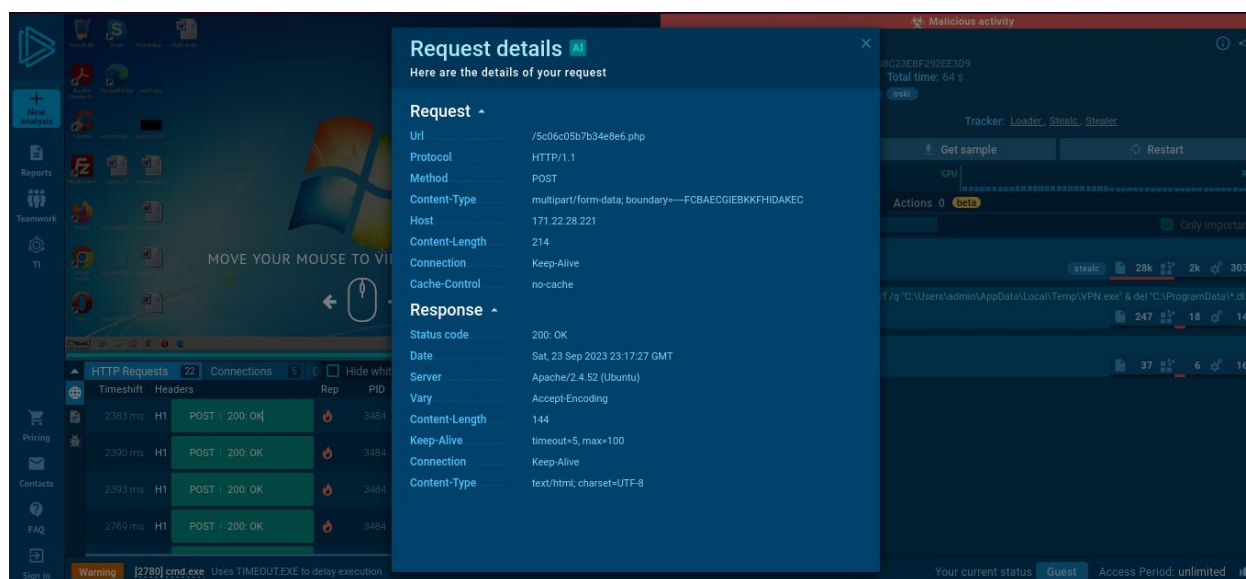
www.virustotal.com/gui/

September 28, 2022, 17:40:46 UTC

Goal: identify the network infrastructure the malware calls out to, since this is the pivot point for blocking, sinkholing, or further infrastructure-mapping work.

Process:

1. Open the ANY.RUN sandbox report for the matching hash and review the “Connections” / network activity panel.
2. Filter for outbound HTTP requests that include suspicious paths (such as .php or .exe endpoints) rather than benign telemetry or CDN traffic.
3. Note the destination IP address that the malware repeatedly contacts for these requests, and confirm it is referenced consistently across the memory strings and network capture.



Finding

171.22.28.221

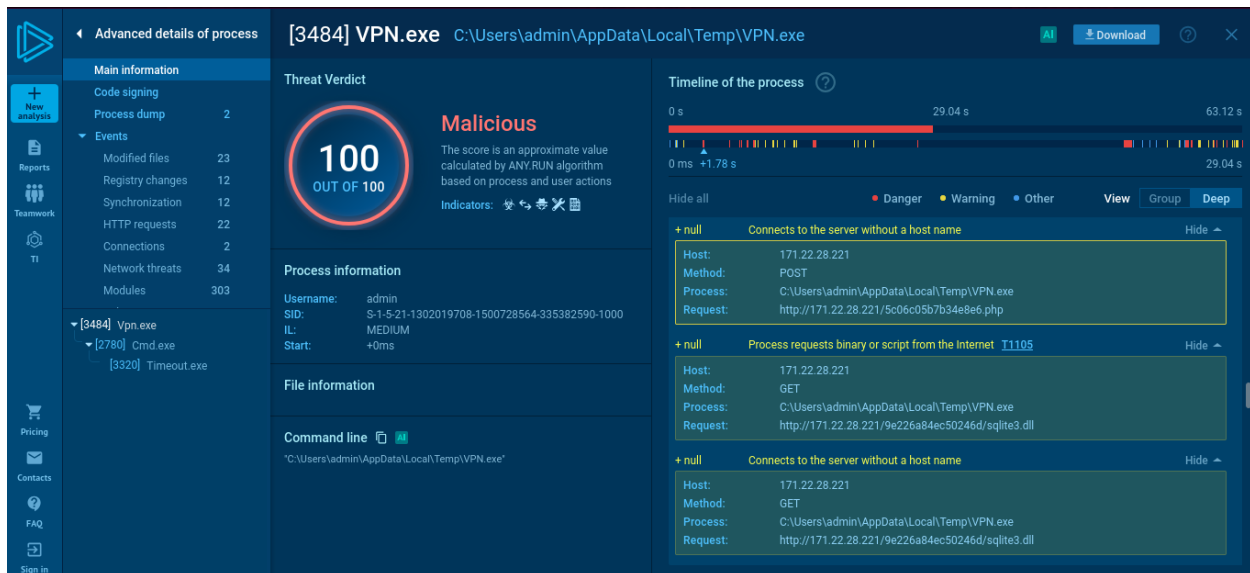
This IP recurs across both memory artifacts and the HTTP request log, and the URLs it serves end in .php (consistent with a PHP-based C2 panel, common for Stealc/Oski-lineage stealers) and .exe (likely a secondary payload or updated build). In a real incident this IP would be added to network blocklists and checked against threat-intel feeds for related infrastructure.

4.4 Objective 4 — First Library Requested Post-Infection

Goal: identify the first DLL the malware loads immediately after execution, which often hints at its primary functional objective.

Process:

1. In the ANY.RUN report, open the process tree and select the main malicious process.
2. Review the “HTTP Requests” / module-loading section in chronological order to find the first library call.
3. Cross-check using ANY.RUN's AI-generated behavioral summary, which independently lists the same library.

**Finding****sqlite3.dll**

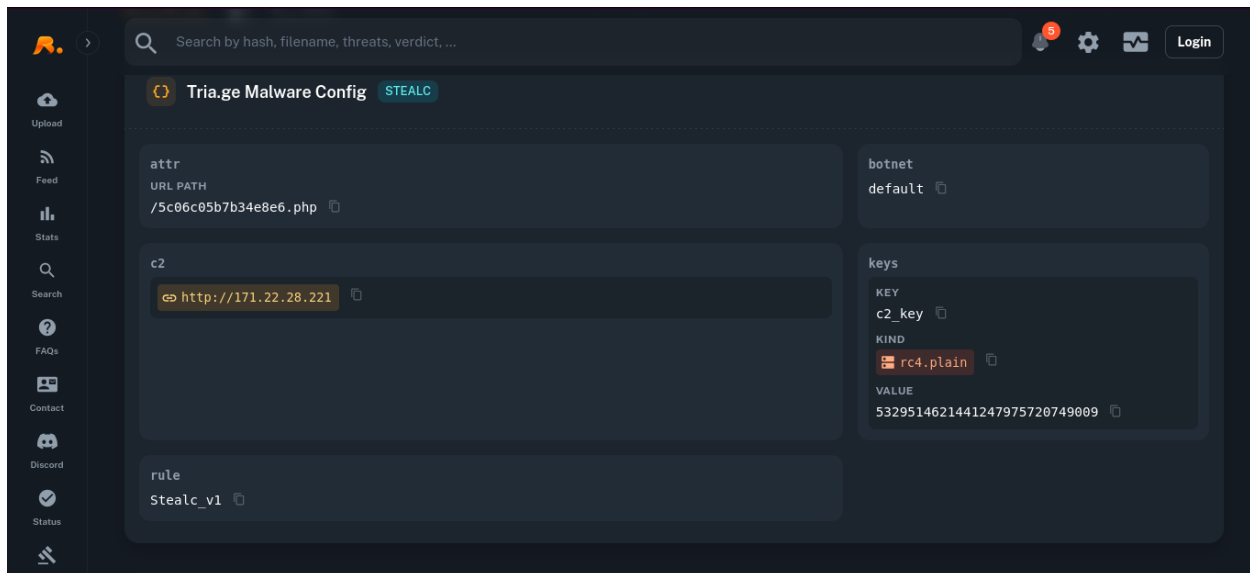
Loading the SQLite engine immediately on execution is a strong signal of credential-theft intent: Chromium- and Firefox-based browsers store saved logins, cookies, and autofill data in local SQLite databases, so an infostealer needs this library to open and query those files directly.

4.5 Objective 5 — RC4 Decryption Key

Goal: recover the symmetric key the malware uses to decrypt its embedded, base64-encoded configuration strings (such as C2 URLs or behavioral flags), which is necessary to fully decode the malware's configuration.

Process:

1. In the ANY.RUN report, open the “MalConf” (malware configuration extractor) panel, which automatically parses known stealer families' obfuscation routines.
2. Locate the listed encryption algorithm (RC4) and the associated key value.



Finding

RC4 key: 5329514621441247975720749009

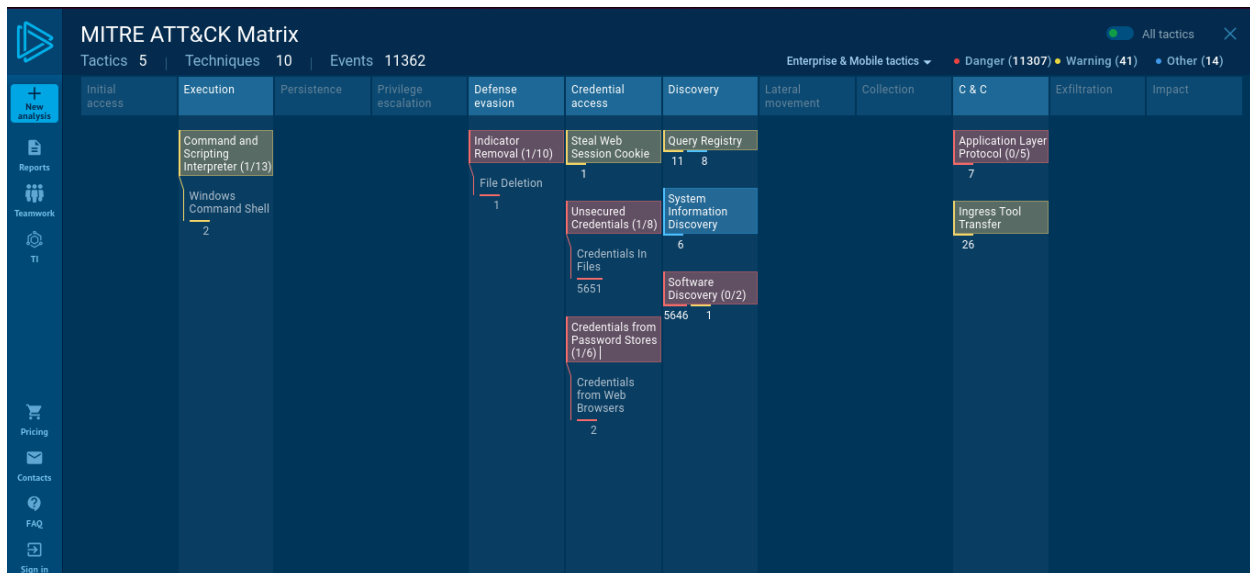
RC4 is a lightweight stream cipher that many stealer families favor because it is fast and trivial to implement, even though it is cryptographically weak by modern standards. Knowing the key lets an analyst fully decrypt the malware's base64-encoded internal strings, exposing the rest of its hardcoded configuration.

4.6 Objective 6 — MITRE ATT&CK Technique for Credential Theft

Goal: map the malware's password-stealing behavior to the correct top-level MITRE ATT&CK technique (not a sub-technique), to standardize the finding for detection engineering and reporting.

Process:

1. In the ANY.RUN report, open the ATT&CK panel, which auto-tags observed behaviors with corresponding framework technique IDs.
2. Browse to the Credential Access tactic column and locate the technique tagged for browser/password-store theft.



Finding

T1555 — Credentials from Password Stores

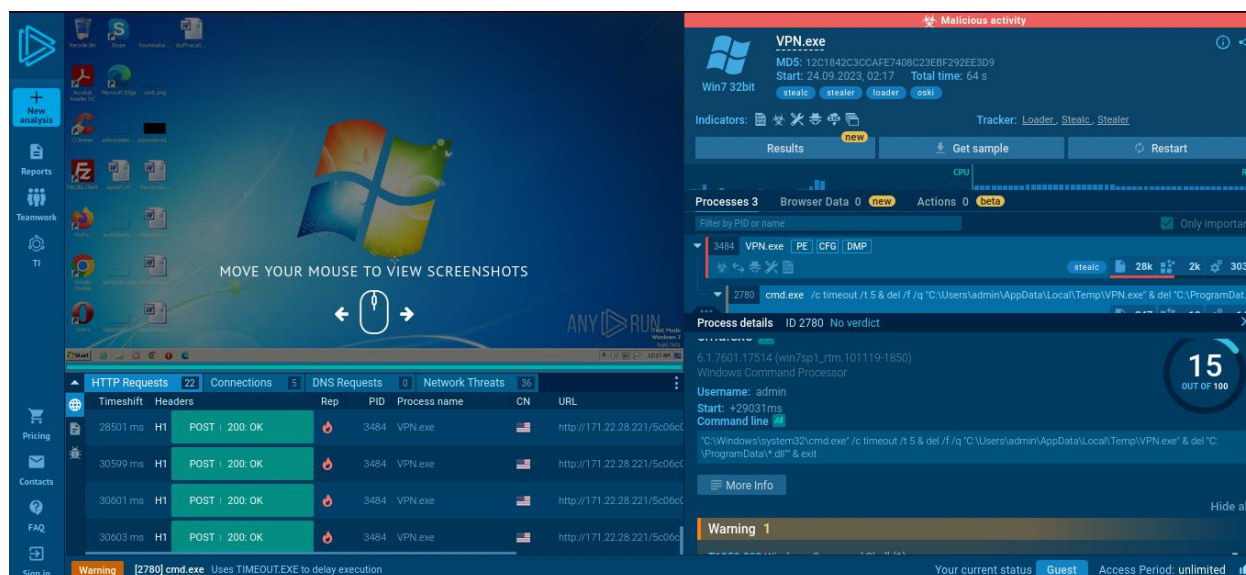
This technique describes adversaries extracting credentials from centralized password storage locations — in this case, browser-saved logins accessed via the `sqlite3.dll` calls identified in Objective 4. Tagging the behavior with a standard technique ID makes the finding directly usable in detection rules, threat reports, and ATT&CK Navigator heat maps.

4.7 Objective 7 — DLL Deletion Directory

Goal: identify where the malware deletes supporting DLL files from as part of its anti-forensic cleanup, since this defines where a responder should look for residual evidence.

Process:

1. In the ANY.RUN process tree, locate the child `cmd.exe` process spawned near the end of execution.
2. Inspect its command line arguments to see the exact deletion targets it was instructed to remove.



Finding

**C:\ProgramData\ (DLLs) and
C:\Users\admin\AppData\Local\Temp\VPN.exe (main binary)**

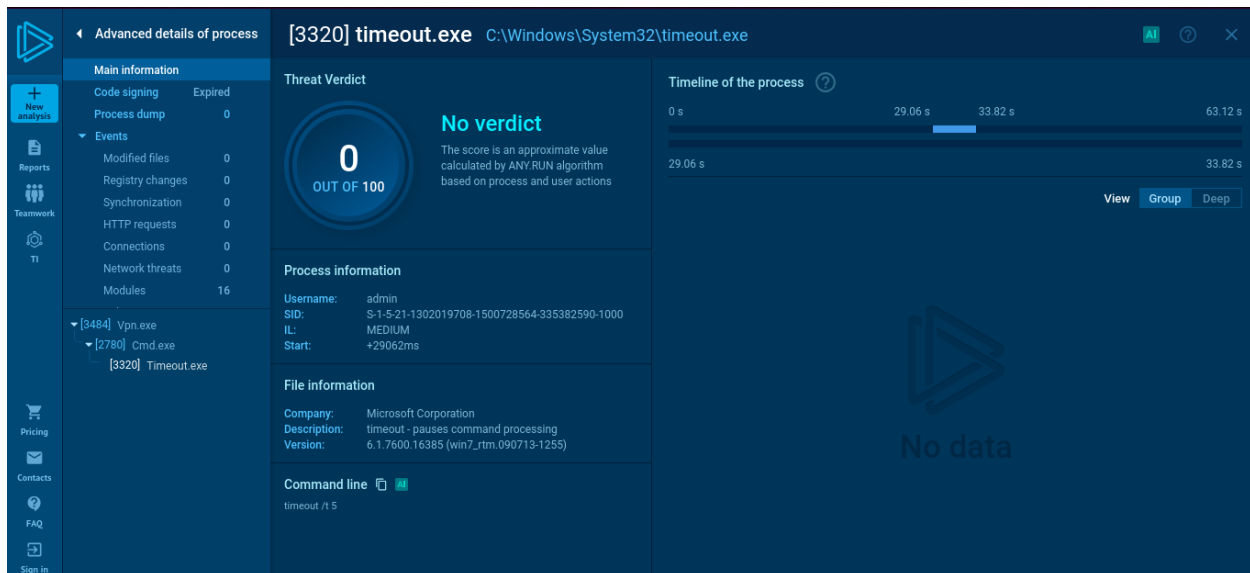
The malware uses a single cmd.exe invocation to remove its primary dropped executable from the user's Temp folder and to wipe any DLLs it staged in C:\ProgramData\, reducing what a responder can recover post-incident. Knowing these exact paths tells an incident responder where to prioritize disk forensics, volume shadow copy review, or memory capture before cleanup completes.

4.8 Objective 8 — Self-Deletion Delay

Goal: determine how long the malware waits, after exfiltrating stolen data, before deleting itself — a detail relevant to building a detection window before evidence disappears.

Process:

1. Continue inspecting the same cmd.exe command line from Objective 7.
2. Identify the timeout/delay value embedded in the deletion command, which pauses execution before the file removal runs.

**Finding****5 seconds**

The five-second pause is just long enough to let in-flight exfiltration requests complete before the malware erases its own tracks. This narrow but real window is the practical opportunity a host-based EDR or a fast-triggering Sysmon rule has to capture the process and its artifacts before they vanish.

5. MITRE ATT&CK Mapping

Consolidating each finding against its corresponding tactic gives a compact, at-a-glance view of the adversary's operational flow from delivery through cleanup.

Tactic	Technique ID	Technique Name	Observed Behavior
Initial Access	T1566.001	Phishing: Spearphishing Attachment	Malicious PPT delivered via "Urgent New Order" email lure
Execution	T1204.002	User Execution: Malicious File	Victim opens the weaponized PPT attachment
Credential Access	T1555	Credentials from Password Stores	sqlite3.dll used to query browser-saved credential databases
Command and Control	T1071.001	Application Layer Protocol: Web Protocols	HTTP communication with C2 at 171.22.28.221 over .php/.exe paths
Defense Evasion	T1027	Obfuscated Files or Information	RC4-encrypted, base64-encoded configuration strings

Tactic	Technique ID	Technique Name	Observed Behavior
Defense Evasion	T1070.004	Indicator Removal: File Deletion	Self-deletion of binary and DLLs 5 seconds post-exfiltration

6. Indicators of Compromise (IOCs)

Type	Value	Context
Malware Family	Stealc (Oski/Vidar lineage)	Crowdsourced VirusTotal IDS detection
Compile Timestamp	2022-09-28 17:40:46 UTC	PE header creation time
C2 IP Address	171.22.28.221	HTTP beacon / data exfiltration endpoint
Loaded Library	sqlite3.dll	First post-infection library load
RC4 Key	5329514621441247975720749009	Decrypts base64-encoded configuration strings
Dropped File	C:\Users\admin\AppData\Local\Temp\VPN.exe	Main executable, deleted post-exfiltration
Cleanup Path	C:\ProgramData*.dll	Supporting DLLs deleted as anti-forensic step
Self-Delete Delay	5 seconds	Timeout before cleanup command executes

7. Conclusion & Recommendations

The Oski lab demonstrates a complete, realistic infostealer kill chain: a socially-engineered Office document lure, a Stealc-family payload that systematically targets browser credential stores via SQLite, RC4-obfuscated configuration data, HTTP-based C2 communication, and a short-delay self-deletion routine designed to outrun forensic response. Working through it using VirusTotal and ANY.RUN rather than live detonation also reinforces a core threat-intel skill: extracting a complete behavioral picture purely by pivoting across existing community sandbox and reputation data.

Based on the observed TTPs, the following defensive actions are recommended for an organization facing a similar campaign:

- Block outbound traffic to 171.22.28.221 and monitor for connections to similarly-structured C2 paths ending in .php or .exe.
- Deploy detection logic for cmd.exe instances that delete their own parent process shortly after spawning, a strong indicator of self-deleting malware.
- Enable browser credential-store hardening (e.g., Windows DPAPI, OS-level credential isolation) to reduce the value of stolen SQLite-based password databases.
- Treat unsolicited “urgent order” or invoice-themed attachments from unfamiliar senders as high-risk, and sandbox Office attachments with macro/embedded-object execution before allowing them to open on end-user devices.
- Tune SIEM detections to alert on sqlite3.dll being loaded by non-browser, non-database processes, since this is an unusual combination outside of legitimate software.

8. References

CyberDefenders. “Oski Lab Official Walkthrough.” cyberdefenders.org/walkthroughs/oski/

CyberDefenders. “Oski Blue Team CTF Challenge.” cyberdefenders.org/blueteam-ctf-challenges/oski/

ANY.RUN Sandbox Report (referenced hash). app.any.run/tasks/d55e2294-5377-4a45-b393-f5a8b20f7d44

MITRE ATT&CK Framework. attack.mitre.org